

in an internal connection to the destination that gets updated in the firewall's own tracking table. Since the source does not exist, such requests keep on piling up, thus exhausting the firewall resources. In another case, the source address is spoofed to be one of the internal network IP range, and the MAC address is spoofed. This causes the destination host to call for a MAC address RARP request, causing turbulence on the internal network. It is important to note that a firewall DoS attack can disrupt internal-to-external network traffic, and can even take down the internal network.

**Packet forging:** In one of the previous articles in this series, we learnt about packet crafting. The same technique can be used against firewalls. In one case, a packet can be crafted to have a bad TCP checksum, which the firewall has to calculate every time, before taking a decision on the packet, thus causing sluggishness. In another case, the data-length parameter in the TCP packet can be filled with a very big number, which tricks the firewall into waiting for the entire data chunk to arrive. This can eventually exhaust the firewall's internal memory.

**Rule exploitation:** Attackers know by experience that, in many cases, a firewall is not configured correctly. For example, it is commonly found that TCP packet rules are set up, whereas the administrator simply forgets to deal with UDP packets, letting those get through the firewall. It has also been found that many firewalls are configured with port 80 being open bi-directionally, whereas it should be open only from the external network to the internal network. Modern black-hats (attackers) often write scripts to detect such mis-configurations—and on finding one, they gather enough data to exploit those further.

## IDS and switch evasion

Today's IT infrastructures always try to go beyond firewalls, by implementing Layer-3 switches as well as intrusion detection systems. A Layer-3 switch contains some great features, such as compartmentalised virtual networks, network bandwidth quality of service, MAC registration, etc. An IDS system works by applying attack anomaly algorithms on the packet traffic in a network. While each of those have their advantages, the techniques used to invade a router and firewall apply to them too. At the heart of all these techniques is packet crafting and packet spoofing, so that these devices are fooled into treating those packets as legitimate—and thus the attack is not sensed, suspected or detected.

One common technique to evade an IDS system is forceful signature embossing. An IDS system learns as time goes by, and updates its own database of anomaly signatures, which further helps in deciding which request is legitimate and which is not. Attackers send multiple spoofed packets over a long period of time, to a destination host running a known TCP service. The

packets are sent in well-formed as well as malformed patterns. The IDS drops the malformed ones, but eventually 'learns' it as an acceptable behaviour based on historic patterns. Once this state is attained, the attacker storms the IDS with malformed packets to the host, thus achieving the goal of disrupting the system. This also shows us that an IDS is a great idea, but a mis-configured IDS can be equivalent to having almost no security at all.

For switches and IDS systems, DoS attacks planted at Layer-2 or Layer-3 are possible. Switches are configured to deal with such situations; however, attackers scan networks to find out the weakest link, which is usually the misconfigured device, and use it as a target. The operating system of switches, too, can be compromised, as attackers can take control of these switches remotely. This is, however, not so easy in case of IDS systems, making these an important network component from the cyber security perspective.

## Protecting FOSS systems

There are many flavours of open source routers running on Ubuntu and other distros. The same is true for firewalls and intrusion detection systems. While we have discussed the devices, it is important to note here that the FOSS systems behind the perimeter of these devices should be properly configured and monitored for network attack anomalies. At the network layer, Linux FOSS systems come with a built-in feature called source address verification. This is a kernel feature which, when turned on, starts dropping packets that appear to be arriving from the internal network, but in reality are not. Most of the latest kernels in distros, such as Ubuntu and CentOS, support it. This feature helps to reduce the chances of packet spoofing.

## Summary

This article concludes this series on cyber security. We all love FOSS, and can enjoy and benefit from it even more only if it is cyber-secured. Thanks for all the great feedback received so far, and the encouraging words via email and social networks. Device evasion is a new trend in network attacks and is being increasingly used to break into corporate IT infrastructure for malicious reasons; it should be taken very seriously by network administrators and the IT senior management. 

### By: Prashant Phatak

The author has over 20 years of experience in IT hardware, networking, Web technologies and IT security. Prashant is MCSE and MCDBA certified, and also an F5 load balancer expert. In the IT security world, he is an ethical hacker and a Net forensic specialist. Prashant runs his own firm, named Valency Networks, in India (<http://www.valencynetworks.com>) providing consultancy in IT security design, security audits, infrastructure technology and business process management. He can be reached at [prashant@valencynetworks.com](mailto:prashant@valencynetworks.com).